Acesso à caixa de e-mail para o robô de faturas

Integração via Microsoft Graph (aplicação não interativa / app-only)

Para: time de Infraestrutura / Administrador do Microsoft 365
De: TI / Ademir (robô de faturas)
Objetivo: permitir que um robô **leia** as faturas que chegam nas caixas abaixo, sem usar a senha das caixas e sem login de usuário.

- `faturas.energia@ilumisol.com.br`
- `matriz@tangisa.com.br`
- `lider@tangisa.com.br`
- `administrativa@tangisa.com.br`

> **Confirmar:** os domínios `ilumisol.com.br` e `tangisa.com.br` estão no **mesmo tenant** do Microsoft 365? Se **sim**, um único app registrado cobre as quatro caixas. Se forem **tenants diferentes**, é preciso repetir o registro (seção 2) e a política (seção 3) em cada tenant, e devolver um conjunto de credenciais por tenant.

1. Por que assim (resumo da decisão)

- As caixas são de uso compartilhado e ninguém tem/deve guardar a senha delas.
- **Não** vamos usar IMAP com senha (basic auth está desativado na maioria dos tenants M365 e guardar senha é inseguro).
- Vamos usar **Microsoft Graph com permissão de aplicativo (app-only / client credentials)**: o robô se autentica com um **certificado ou segredo** do próprio aplicativo registrado, e lê **somente** as caixas autorizadas.
- O acesso é **somente leitura** (`Mail.Read`) e **restrito a essas 4 caixas** por uma *Application Access Policy*. O app **não** enxerga nenhuma outra caixa da organização.

2. Passo a passo no Entra admin center (portal Azure)

2.1. Registrar o aplicativo

1. Entra admin center → **Identity** → **Applications** → **App registrations** → **New registration**.
2. Nome: `RPA-Faturas-Email` (sugestão).
3. Supported account types: **Accounts in this organizational directory only** (single tenant).
4. **Register**.
5. Anotar da tela *Overview*: **Application (client) ID** e **Directory (tenant) ID**.

2.2. Credencial do app (escolher UMA — ver seção 5)

- **Opção A — Certificado (recomendado p/ produção):** *Certificates & secrets* → *Certificates* → *Upload certificate* (geramos o par de chaves e enviamos só o `.cer` público; a chave privada fica com o robô).

- **Opção B — Segredo (mais simples):** *Certificates & secrets → Client secrets → New client secret →* validade (ex.: 12 ou 24 meses) → **copiar o Value na hora** (só aparece uma vez).

2.3. Permissão de API (Graph, somente leitura)

1. *API permissions → Add a permission → Microsoft Graph →* ***Application permissions***.
2. Marcar `Mail.Read`.
   (Opcional, só se quiserem que o robô marque como lido / mova pra uma pasta "Processadas": adicionar também `Mail.ReadWrite`. Por padrão pedimos só `Mail.Read` — ver seção 5.)
3. **Grant admin consent for <tenant>** (precisa de admin). O status deve ficar **verde/Granted**.

3. Restringir o app a apenas as 4 caixas (Exchange Online PowerShell)

> Isso é o que impede o app de ler qualquer outra caixa. Sem isso, `Mail.Read` de aplicativo daria acesso a **todas** as caixas.

```
# Conectar ao Exchange Online (modulo ExchangeOnlineManagement)
Connect-ExchangeOnline

# 1) Grupo de seguranca com correio contendo SO as 4 caixas de faturas
New-DistributionGroup -Name "RPA-Faturas-Scope" -Type Security `
  -Members
"faturas.energia@ilumisol.com.br","matriz@tangisa.com.br","lider@tangisa.com.br","administra
tiva@tangisa.com.br"

# 2) Politica que limita o app a esse grupo (use o Application (client) ID do passo 2.1)
New-ApplicationAccessPolicy -AppId "<CLIENT_ID>" `
  -PolicyScopeGroupId "RPA-Faturas-Scope@<dominio-do-grupo>" `
  -AccessRight RestrictAccess `
  -Description "Robo faturas - acesso somente as caixas de faturas"

# 3) Testar: deve retornar AccessCheckResult = Granted para CADA caixa autorizada
Test-ApplicationAccessPolicy -Identity "faturas.energia@ilumisol.com.br" -AppId "
<CLIENT_ID>"
Test-ApplicationAccessPolicy -Identity "matriz@tangisa.com.br"          -AppId "<CLIENT_ID>"
Test-ApplicationAccessPolicy -Identity "lider@tangisa.com.br"           -AppId "<CLIENT_ID>"
Test-ApplicationAccessPolicy -Identity "administrativa@tangisa.com.br"  -AppId "<CLIENT_ID>"

# (opcional) conferir que uma caixa QUALQUER da Denied:
# Test-ApplicationAccessPolicy -Identity "qualquer.outro@<seu-dominio>" -AppId "<CLIENT_ID>"
```

> **Observações:**
>
> - O grupo precisa ser **mail-enabled** (o `New-DistributionGroup -Type Security` cria assim). O `PolicyScopeGroupId` é o **endereço de e-mail** desse grupo.
> - Se as caixas estiverem em **tenants diferentes**, rode este bloco em cada tenant, com os membros daquele tenant e o `CLIENT_ID` do app daquele tenant.
> - A propagação da política pode levar alguns minutos.

4. O que devolver para a TI (pra plugar no robô)

Item	Onde pega	Exemplo
Directory (tenant) ID	Overview do app	`00000000-0000-0000-0000-000000000000`
Application (client) ID	Overview do app	`11111111-1111-1111-1111-111111111111`
Segredo ou **certificado**	passo 2.2	o "Value" do segredo, ou confirmação do cert enviado
E-mails das caixas	Exchange	`faturas.energia@ilumisol.com.br, matriz@tangisa.com.br, lider@tangisa.com.br, administrativa@tangisa.com.br`
Pasta(s) a ler	—	Caixa de Entrada (faturas chegam direto ou como CC)
Mesmo tenant?	—	confirmar se as 4 caixas estão no mesmo tenant M365

> O segredo/senha **não** deve ir por e-mail aberto — enviar por um canal seguro (cofre de senha / mensagem que expira).

5. Decisões que a infra escolhe

1. **Certificado (A) × Segredo (B):** certificado é o padrão de produção (não expira "sem avisar" num texto em claro); segredo é mais rápido de montar mas exige rotação antes de expirar. **Recomendo certificado**; se quiserem começar rápido, segredo com validade de 12–24 meses resolve.
2. **Somente leitura × marcar como lido:** por padrão só `Mail.Read` (não altera nada na caixa — o robô controla sozinho o que já processou). Se preferirem que o robô **marque como lido** ou **mova pra uma pasta "Processadas"**, aí precisa de `Mail.ReadWrite`.

6. Como o robô vai usar (contexto — infra não faz nada aqui)

- Autentica por **OAuth2 client credentials** em `https://login.microsoftonline.com/<tenant>/oauth2/v2.0/token`, scope `https://graph.microsoft.com/.default`.
- Lê mensagens e anexos por `GET https://graph.microsoft.com/v1.0/users/<email-da-caixa>/mailFolders/Inbox/messages` e `.../messages/<id>/attachments`, **uma caixa de cada vez** (as 4 da lista).
- Baixa o PDF da fatura, extrai os dados e devolve ao CRM. **Não envia e-mail, não apaga nada.**

7. Segurança (resumo pra aprovação)

- Escopo **mínimo**: só leitura, só **as 4 caixas da lista** (Application Access Policy).
- Sem senha de usuário/caixa em lugar nenhum.

- Credencial do app rotacionável/revogável a qualquer momento (desativar o app corta o acesso na hora).
- O robô roda na infra interna (NUC) e só fala com Microsoft Graph (HTTPS) e com o CRM da empresa.